

AUTO-AUDITORIA NIS2 — SIMULAÇÃO DE VISTORIA CNCS

Realizar 2-3 meses antes de qualquer auditoria CNCS · Identificar e corrigir gaps antecipadamente

Como usar: Simule que é um auditor do CNCS. Marque ■ apenas o que tem evidência real e verificável. Sem evidência = ■.
Objetivo: identificar gaps ANTES da visita real. Cada ■ = potencial não conformidade a corrigir. Score final: nº de ■ / total de itens aplicáveis.

IDENTIFICAÇÃO DA AUTO-AUDITORIA

Empresa:

Data:

Realizada por (CISO):

1. GOVERNANÇA E REGISTO

☐	Registo no CNCS efectuado e dados actualizados (NIF, CISO, IPs, sectores) Evidência: Confirmação email CNCS + número de referência	CRÍTICO
☐	CISO nomeado formalmente com carta assinada pelo CEO Evidência: Carta de nomeação com data e assinatura do CEO	CRÍTICO
☐	Gestão de topo recebeu formação em cibersegurança este ano (Art. 20.º NIS2) Evidência: Certificados de formação dos gestores	CRÍTICO
☐	Reunião trimestral de cibersegurança com gestão de topo realizada (ata) Evidência: Atas das últimas 4 reuniões com KPIs apresentados	ALTO
☐	Orçamento de cibersegurança aprovado formalmente para o ano corrente Evidência: Documento orçamental aprovado com rubrica de cibersegurança	ALTO

2. ANÁLISE DE RISCO E POLÍTICAS

☐	Análise de Risco formal realizada nos últimos 12 meses com metodologia documentada Evidência: Registo de Riscos com data, metodologia e aprovação da gestão	CRÍTICO
☐	PSI (Política de Segurança da Informação) aprovada, assinada e distribuída Evidência: PSI com data ≤12 meses, assinatura CEO, confirmações de leitura dos colaboradores	CRÍTICO
☐	Inventário de ativos críticos actualizado (hardware, software, cloud, dados) Evidência: Inventário com data recente e responsável atribuído a cada ativo	ALTO
☐	Todos os colaboradores assinaram a Checklist de Higiene Cibernética este ano Evidência: Checklists assinadas por 100% dos colaboradores	ALTO

3. MEDIDAS TÉCNICAS — 10 MEDIDAS NIS2

☐	MFA activo em 100% das contas e sistemas críticos (email, VPN, ERP, cloud, admin)	CRÍTICO
--------------------------	--	---------

☐	Backup 3-2-1 com imutabilidade configurado — testado com RTO medido no último trimestre	CRÍTICO
Evidência:	<i>Relatório de teste de restauro com RTO medido e assinado pelo responsável TI</i>	
☐	Processo de patches documentado — CVSS≥9 aplicados em ≤48h, registo evidenciado	CRÍTICO
Evidência:	<i>Relatório trimestral de patches: CVSSs críticos com data de aplicação</i>	
☐	BitLocker/FileVault activo em todos os portáteis e dispositivos móveis corporativos	ALTO
Evidência:	<i>Relatório do Intune/MDM com % de dispositivos encriptados</i>	
☐	Segmentação de rede implementada (VLAN: produção / office / Wi-Fi visitantes / IoT)	ALTO
Evidência:	<i>Diagrama de rede actualizado + configuração VLAN documentada</i>	
☐	Logs de segurança retidos ≥12 meses e monitorizados (alertas automáticos activos)	ALTO
Evidência:	<i>Configuração de retenção + evidência de monitorização activa de alertas</i>	
☐	Scan de vulnerabilidades realizado no último trimestre (externo + interno)	ALTO
Evidência:	<i>Relatório de scan com vulnerabilidades identificadas e estado de remediação</i>	
☐	Sistemas End-of-Life substituídos ou isolados em VLAN sem acesso à internet	MÉDIO
Evidência:	<i>Inventário de EOL + prova de isolamento ou plano de substituição</i>	

■ 4. CADEIA DE ABASTECIMENTO (TPRM)

☐	Inventário de fornecedores TPRM actualizado com score de risco	ALTO
Evidência:	<i>Inventário TPRM com data recente e scores calculados</i>	
☐	Questionários Due Diligence respondidos para todos os fornecedores críticos (score ≥10)	ALTO
Evidência:	<i>DD respondidos e assinados pelos fornecedores críticos + data</i>	
☐	Contratos com fornecedores críticos incluem 5 cláusulas NIS2 (notificação 24h, auditoria, etc.)	ALTO
Evidência:	<i>Contratos ou adendas assinadas com cláusulas NIS2 visíveis</i>	
☐	Plano de Saída (Exit Strategy) documentado para fornecedores críticos	MÉDIO
Evidência:	<i>Excel com alternativas, portabilidade de dados e prazo de migração</i>	

■ 5. GESTÃO DE INCIDENTES

☐	IRP (Plano de Resposta a Incidentes) documentado e testado com tabletop nos últimos 6 meses	CRÍTICO
Evidência:	<i>IRP actualizado + relatório de tabletop exercise com data ≤6 meses</i>	
☐	Log de incidentes mantido com TODOS os eventos (incluindo não reportáveis)	CRÍTICO
Evidência:	<i>Log de incidentes com entradas do ano corrente — incluindo quase-incidentes</i>	
☐	Equipa conhece os prazos NIS2: 24h aviso, 72h notificação, 1 mês relatório final	CRÍTICO
Evidência:	<i>Evidência de formação sobre prazos (formação anual ou tabletop)</i>	

☐	Canais de comunicação alternativos activos e testados (Signal/WhatsApp de emergência) Evidência: Grupo Signal criado com todos os membros da equipa de resposta activos	ALTO
☐	Cartão de Emergência NIS2 plastificado e afixado na sala de TI e War Room Evidência: Fotografia do cartão afixado (evidência visual)	MÉDIO

6. FORMAÇÃO E SENSIBILIZAÇÃO

☐	Formação anual de cibersegurança realizada para 100% dos colaboradores este ano Evidência: Lista de presenças assinada por todos os colaboradores + certificados	CRÍTICO
☐	Simulação de phishing trimestral realizada — taxa de cliques registada Evidência: Relatório trimestral com taxa de cliques. Meta: <5%	ALTO
☐	Novos colaboradores recebem formação de cibersegurança no onboarding Evidência: Registo de formação de onboarding + checklist de higiene assinada	ALTO

7. DOSSIER DE CONFORMIDADE

☐	Dossier NIS2 organizado com todos os 28 documentos do Índice Mestre catalogados Evidência: Excel Índice Mestre actualizado com localização de cada documento	CRÍTICO
☐	Todos os documentos críticos com estado '■ Existe e válido' no Índice Mestre Evidência: Score de conformidade do Índice Mestre ≥ 80%	CRÍTICO
☐	Calendário Anual de Conformidade actualizado para o ano corrente Evidência: Excel Calendário com actividades do ano e estado actualizado	ALTO
☐	Relatório Anual de Cibersegurança preparado para apresentação à gestão Evidência: Relatório com KPIs do ano, incidentes, conformidade e orçamento	ALTO

RESULTADO DA AUTO-AUDITORIA

Score: ■ de itens aplicáveis = % de conformidade

Gaps identificados (■): itens — criar CAPA para cada gap crítico antes da visita CNCS

Realizada por (CISO): Data: